Introduction to AI Threat Modeling

CompTIA SecAI+ CertMaster Study — Section 2.1.1

What is AI Threat Modeling?

AI threat modeling is a process of identifying potential threats and analyzing the risks associated with AI systems. Traditional threat modeling will not address the unique vulnerabilities introduced by AI, such as **data poisoning, prompt injection, or model extraction attacks**. This process helps security teams analyze applications and identify both traditional and AI-related threats.

Data Poisoning

Corrupting training data to manipulate model behavior

Prompt Injection

Crafting inputs to hijack AI model responses

Model Extraction

Stealing model logic through repeated queries

Why Do We Need AI Threat Modeling?

AI has evolved from simple automation to **generating synthetic information, decision-making, real-time assistance, learning from conversations, and connecting complex systems**. The usage of AI is not just confined to one industry or use case; it has been extended to support humans in multiple activities across various sectors.

Knowledge Bots

AI-powered bots delivering information and answering queries across industries

Coding Assistants

AI tools that help developers write, review, and debug code in real time

Interactive Customer Assistants

AI-driven customer support agents providing real-time assistance

Fraud Detection

AI systems analyzing patterns to identify and prevent fraudulent activity

Risks of AI Without Threat Modeling

Confidentiality Risk

AI requires access to data, internal systems, and applications. Improper configuration of access controls and guardrails could provide **sensitive information to unauthorized users**, compromising the organization's data and affecting confidentiality.

Integrity Risk

Attackers can **jailbreak AI models and perform data poisoning**, leading to data integrity issues and spreading misinformation.

Availability Risk

Lack of rate limitation on AI usage leads to **unlimited utilization of services**, causing exhaustion of back-end resources, financial impact, and availability issues.

How AI Threat Modeling Differs from Traditional Approaches

Unlike the threat modeling of a conventional application, this process focuses on several unique aspects and a step-by-step approach within AI application architecture to identify threats. AI systems need more computational power, so it is essential to understand the infrastructure where the application is hosted, as well as its scalability.

Unique AI Architecture Focus

A step-by-step approach within AI application architecture is required to identify threats specific to AI systems.

Infrastructure Awareness

AI systems need more computational power, so it is essential to understand the infrastructure where the application is hosted, as well as its scalability.

Data and Access Considerations

Data Sources & Training

Focusing on sources of data and the type of data used for training models is required, as data collection can introduce threats such as **biases, misinformation, or harmful content** being shared with users.

Access Control Analysis

It is important to analyze how access is provided to AI and its underlying back-end systems for performing various actions, such as **retrieving, modifying, and deleting data**. Misconfiguration of access controls would help adversaries gain access to data and perform malicious activities.

Supply Chain and Model Risks

Evaluating the different types of AI models used in applications, such as **third-party models or in-house developed models**, is required to analyze the supply chain risks.

Third-Party Models

External AI models introduce supply chain dependencies and potential vulnerabilities from outside the organization.

In-House Developed Models

Internally built models require rigorous evaluation of development practices and internal supply chain integrity.

Supply Chain Risk Analysis

Evaluating all model types is required to fully understand and mitigate supply chain risks in AI applications.

Data Security and Guardrails

AI applications work by collecting data from users and responding back with information, so **data shared with AI systems must be stored and processed securely**. Evaluating the guardrails implemented around AI usage will help prevent sensitive information leakages and set up boundaries on how AI must respond to users based on organizational standards.

Data Collection

Users share data with AI systems during interactions

Secure Storage & Processing

Data must be stored and processed securely at all times

Guardrail Evaluation

Guardrails prevent sensitive leakage and enforce organizational response standards

Logging, Monitoring, and Compliance

AI systems are highly unpredictable, and **user interactions with AI have to be logged and monitored** to observe changes in model behavior. Assessing AI logging and monitoring controls should include data classification, storage, retention, and relevant regulatory requirements for effective security compliance and monitoring.

1

Log User Interactions

Capture all AI interactions to detect behavioral anomalies and unexpected model outputs.

2

Data Classification & Storage

Classify logged data appropriately and ensure secure, compliant storage practices.

3

Retention Policies

Define and enforce data retention schedules aligned with organizational and regulatory requirements.

4

Regulatory Compliance

Incorporate relevant regulatory requirements for effective security compliance and monitoring.

New Threat Surfaces

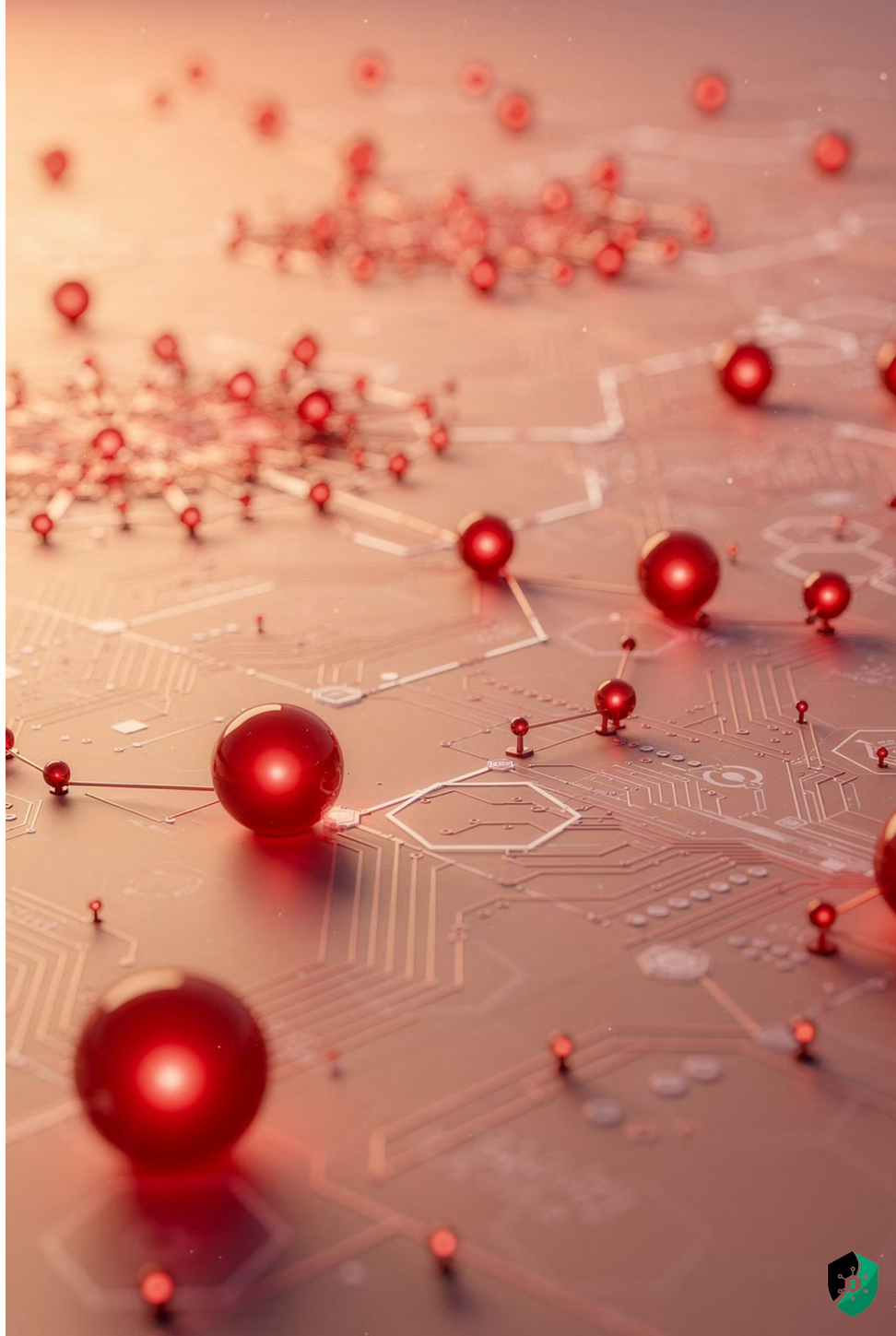
> AI systems can introduce new threat surfaces and attack vectors, unlike traditional applications. Hence, a threat modeling specific to AI systems is needed.

Traditional Applications

Known, well-documented threat surfaces with established modeling frameworks

AI Systems

New and unique threat surfaces and attack vectors requiring AI-specific threat modeling



Key Takeaways

AI Threat Modeling Defined

AI threat modeling identifies potential threats and analyzes risks specific to AI systems, covering vulnerabilities like **data poisoning, prompt injection, and model extraction attacks**.

Unique AI Architecture Focus

Unlike traditional threat modeling, AI threat modeling focuses on unique aspects of AI architecture including **infrastructure, data sources, access controls, model types, and supply chain risks**.

Data Security and Guardrails

Data security and guardrails are essential to prevent sensitive information leakage and ensure AI responds within organizational standards.

Logging and Monitoring

Logging and monitoring of AI interactions is critical for observing model behavior changes and maintaining security compliance.

New Threat Surfaces

AI systems introduce **new threat surfaces and attack vectors** that require specialized threat modeling.

Early SDLC Integration

Performing AI threat modeling early in the **Secure Software Development Life Cycle (SDLC)** helps identify and prevent risks associated with AI in applications.